

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS: 20

Annexure A MOCK INTERVIEW

Code of Conduct:

I Y.Naga Tharuni/192372338 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Naga Tharuni

Annexure A

MOCK INTERVIEW

1. Which would you prioritize in a secure network design: **performance or security**, and how would you balance both?
2. Can you explain the difference between **stateful and stateless firewalls**, and which one is more suitable for enterprise networks?
3. If an IDS generates too many false positives, how would you optimize its performance?
4. How would you design a **real-time intrusion detection system** for high-speed networks?
5. What are the key challenges in detecting **zero-day malware**, and how would you address them?
6. How would you differentiate between **signature-based and anomaly-based IDS**, and when would you use each?
7. If a network is under a **DDoS attack**, what immediate and long-term mitigation strategies would you apply?
8. How would you secure **remote access** to an enterprise network?
9. What are the limitations of **traditional antivirus software**, and how can modern solutions overcome them?
10. How would you design a **secure email filtering system** to prevent phishing and spam attacks?
11. If an attacker bypasses firewall rules, what additional layers of security would you implement?
12. How would you evaluate the effectiveness of **network segmentation** in preventing cyberattacks?
13. What role does **encryption** play in preventing malware attacks, if any?
14. How would you secure a **cloud-based network infrastructure**?
15. What is the importance of **log analysis and monitoring** in network security?
16. How would you respond to a **security breach in a corporate network**?
17. What are the advantages and limitations of **next-generation firewalls (NGFW)**?
18. How would you integrate **IDS/IPS with SIEM systems** for better threat detection?
19. What are the best practices for **patch management and vulnerability assessment**?
20. How would you design a **future-proof network security architecture** considering emerging threats?

Answers

1. Performance or security?

I would prioritize security, but I would not ignore performance. A secure network that is too slow is also not practical. I would balance both by using efficient security controls, traffic prioritization, optimized firewall rules, load balancing, and hardware acceleration where required. I would continuously monitor latency, throughput, and security events to maintain an acceptable balance.

2. Stateful vs. stateless firewall

A stateless firewall checks each packet independently using predefined rules such as IP address, port, and protocol. A stateful firewall maintains information about active connections and understands whether a packet belongs to an established session.

For an enterprise network, I would generally prefer a stateful firewall because it provides better context-aware security and can block unexpected packets that do not belong to valid connections.

3. IDS has too many false positives

First, I would analyze why the false positives are occurring. I would tune detection rules, adjust thresholds, remove irrelevant rules, and whitelist trusted activities where appropriate. I would also improve feature selection and, if machine learning is used, retrain the model using more representative data.

The goal is to reduce false positives without increasing false negatives.

4. Real-time IDS for high-speed networks

I would design it using a combination of high-performance packet capture, traffic filtering, parallel processing, and efficient detection algorithms. I would extract only important features and process traffic concurrently.

For very high-speed networks, I would distribute the workload across multiple sensors and use centralized monitoring. I would also define strict latency requirements and continuously measure throughput, detection accuracy, and false-positive rate.

5. Zero-day malware

The main challenge is that zero-day malware has no previously known signature, so traditional signature-based detection may not recognize it.

I would address this using multiple techniques such as:

- Behavioral analysis
- Anomaly detection
- Machine learning
- Sandboxing
- Endpoint detection and response
- Threat intelligence
- Continuous monitoring

A layered approach is important because no single detection technique can identify every zero-day attack.

6. Signature-based vs. anomaly-based IDS

Signature-based IDS compares network activity with known attack patterns. It is fast and accurate for known threats but struggles with new attacks.

Anomaly-based IDS learns what normal behavior looks like and identifies significant deviations. It can detect previously unknown attacks but may generate more false positives.

I would use signature-based detection for known threats and anomaly-based detection for unknown or evolving threats. In practice, I would combine both.

7. DDoS attack mitigation

Immediately, I would identify the affected services and traffic patterns, apply rate limiting and filtering, block clearly malicious sources, and use upstream DDoS protection if available.

For long-term protection, I would implement:

- Traffic monitoring
- Rate limiting
- Load balancing
- Redundant infrastructure
- CDN or DDoS protection services
- Capacity planning
- Incident-response procedures

The important point is to maintain service availability while filtering attack traffic.

8. Securing remote access

I would use a VPN or Zero Trust remote-access solution, combined with strong authentication and preferably multi-factor authentication.

I would also apply:

- Role-based access control
- Least privilege
- Device security checks
- Encryption
- Session monitoring
- Login auditing
- Automatic session timeouts

Remote users should receive only the access they actually need.

9. Limitations of traditional antivirus

Traditional antivirus mainly depends on known signatures, so it can struggle with zero-day, polymorphic, and heavily obfuscated malware.

Modern solutions improve protection using behavioral analysis, machine learning, cloud-based threat intelligence, sandboxing, and Endpoint Detection and Response (EDR). These technologies can detect suspicious behavior even when a specific malware signature is unavailable.

10. Secure email filtering

I would design multiple filtering layers. First, I would check the sender, domain reputation, and authentication mechanisms such as SPF, DKIM, and DMARC.

Then I would analyze:

- URLs
- Attachments
- File types
- Message content
- Sender behavior
- Known spam and phishing patterns

Suspicious messages can be quarantined or subjected to sandbox analysis. User reporting should also feed back into the detection system.

11. Attacker bypasses firewall

I would use defense in depth rather than depending only on the firewall.

Additional layers could include:

- IDS/IPS
- Network segmentation
- Endpoint security/EDR
- Strong authentication
- Access control
- Encryption
- SIEM monitoring
- Vulnerability management
- Application security

So, bypassing one security layer would not give the attacker unrestricted access.

12. Evaluating network segmentation

I would evaluate whether segmentation successfully limits lateral movement after an initial compromise.

I would test:

- Communication between network segments

- Access-control rules
- Isolation of critical systems
- Attack-path reduction
- Unauthorized cross-segment traffic
- IDS/IPS alerts

A successful segmentation design should ensure that compromising one segment does not automatically provide access to critical systems in another segment.

13. Encryption and malware

Encryption does not directly prevent malware. Its primary purpose is to protect confidentiality and integrity.

However, encryption can protect credentials and sensitive information from being intercepted during transmission. The challenge is that attackers can also use encrypted communication to hide malicious traffic.

Therefore, security systems may need encrypted-traffic analysis and endpoint monitoring in addition to encryption itself.

14. Securing cloud infrastructure

I would use a defense-in-depth and least-privilege approach.

Important controls include:

- Strong IAM
- MFA
- Network segmentation
- Encryption at rest and in transit
- Secure configurations
- Security groups/firewall rules
- Continuous logging and monitoring
- Vulnerability scanning
- Backup and recovery
- Regular security audits

I would also follow the cloud provider's shared-responsibility model carefully.

15. Importance of log analysis

Logs provide evidence about what happened, when it happened, and which systems or accounts were involved.

Centralized log analysis helps detect unusual behavior, investigate incidents, identify attack patterns, and support forensic analysis.

I would integrate important logs into a SIEM, where events can be correlated and alerts can be generated automatically.

16. Responding to a security breach

I would follow an incident-response process:

Identify → Contain → Eradicate → Recover → Review

First, I would identify the affected systems and preserve evidence. Then I would isolate compromised systems to prevent further spread.

Next, I would remove the cause of the breach, patch vulnerabilities, reset compromised credentials, restore systems safely, and monitor for reinfection. Finally, I would perform a post-incident review to prevent recurrence.

17. Advantages and limitations of NGFW

A Next-Generation Firewall provides more than traditional packet filtering. It can provide application awareness, user-based policies, intrusion prevention, URL filtering, and sometimes malware detection.

Advantages:

- Better application visibility
- Advanced traffic inspection
- Integrated security features
- User-aware policies

Limitations:

- Higher cost
- Greater configuration complexity
- Additional processing overhead
- Requires skilled administration

So, NGFWs provide stronger protection, but they must be properly configured and maintained.

18. IDS/IPS with SIEM

I would send IDS/IPS alerts and relevant network logs to the SIEM.

The SIEM can correlate these events with authentication logs, firewall logs, endpoint alerts, and other sources. For example, an IDS alert combined with multiple failed login attempts could indicate a coordinated attack.

This improves visibility and allows automated alerting and incident investigation.

19. Patch management and vulnerability assessment

I would maintain an inventory of systems and regularly scan them for vulnerabilities. Vulnerabilities should be prioritized based on severity, exploitability, and business impact.

Best practices include:

- Regular vulnerability scanning
- Timely security patches
- Testing patches before deployment
- Prioritizing critical vulnerabilities
- Tracking patch status
- Removing unsupported software
- Regular verification

Patch management should be a continuous process rather than a one-time activity.

20. Future-proof network security architecture

I would use a layered, adaptive architecture rather than relying on a single security product.

My design would include:

Zero Trust + IAM/MFA + Network Segmentation + NGFW + IDS/IPS + EDR + SIEM + Encryption + Continuous Monitoring

I would also design the architecture to support cloud, IoT, AI-driven attacks, remote work, and emerging technologies.

Most importantly, I would continuously update threat intelligence, security policies, detection models, and incident-response procedures. A future-proof architecture should be scalable, observable, adaptable, and resilient.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Technical Knowledge	25	Demonstrates strong and accurate subject knowledge with in-depth understanding	Shows good knowledge with minor gaps	Basic knowledge with noticeable errors	Lacks fundamental technical knowledge
Problem Solving	25	Solves problems logically and applies concepts effectively in real scenarios	Applies concepts with moderate accuracy	Limited problem-solving ability; requires guidance	Unable to solve or apply concepts
Analytical Thinking	15	Analyzes questions critically and provides well-structured, logical answers	Provides reasonable analysis with some structure	Superficial or partially structured responses	No analytical thinking demonstrated
Communication	15	Communicates clearly, confidently, and professionally with proper terminology	Communicates well with minor hesitation	Communication lacks clarity or confidence	Unable to communicate effectively
Confidence	15	Displays high confidence, positive	Shows good confidence with minor issues	Low confidence; inconsistent behavior	Lacks confidence and professionalism

		attitude, and professional behavior throughout			sm
--	--	---	--	--	----